

الإلكتروني / أمن البريد Electronic Mail Security

Lecture 3 + Lecture 4 - Treasure of the Lecture / كنز المحاضرة

طريقة المذاكرة: احفظ المصطلح الإنجليزي مع معناه العربي، ثم احفظ الفكرة القصيرة تحته. هذا الملف يغطي موضوعات السلايدات المهمة: البروتوكولات، الصيغ، التهديدات، SPF، DKIM، DNSSEC، DANE، S/MIME، و DMARC.

تحليل هيكل المحاضرتين / Lecture Structure Analysis

المحاور الرئيسية	عدد السلايدات	Lecture / المحاضرة
بنية البريد الإلكتروني، SMTP/STARTTLS، POP3/IMAP، RFC 5322، MIME، تهديدات البريد، بروتوكولات الحماية، S/MIME وخطواته وخدماته.	36	Lecture 3 - Electronic Mail Security Part 1
TLSA، SPF، DKIM و DNSSEC، DANE و PGP/OpenPGP، DNS، DMARC، وتكامل بروتوكولات حماية البريد.	25	Lecture 4 - Electronic Mail Security Part 2

الخلاصة الكبرى: أمن البريد الإلكتروني يعتمد على طبقات: Transport security مثل STARTTLS، و Message security مثل S/MIME/PGP، و Domain authentication مثل SPF/DKIM/DMARC، و DNS trust مثل DNSSEC/DANE.

Lecture 3 / المحاضرة الثالثة

Electronic Mail Security Part 1 / أمن البريد الإلكتروني - الجزء الأول

Internet Mail Architecture / معمارية البريد الإلكتروني (1)

المكونات الأساسية / Main Components

المكون	المعنى	وظيفته الامتحانية المختصرة
MUA - Message User Agent وكيل مستخدم الرسالة	برنامج المستخدم مثل تطبيق البريد.	ينشئ الرسالة ويرسلها أولاً، ويستقبل/يعرض الرسائل للمستخدم.
MSA - Mail Submission Agent وكيل تسليم/إرسال البريد	النقطة الأولى داخل نظام البريد.	يطبق سياسات الدومين المستضيف ومتطلبات معايير الإنترنت.
MTA - Message Transfer Agent وكيل نقل الرسائل	خوادم تمرير البريد عبر الإنترنت.	ينقل الرسالة بين المصدر والوجهة باستخدام SMTP.
MDA - Mail Delivery Agent وكيل تسليم الرسائل	آخر مرحلة قبل صندوق البريد.	ينقل الرسالة من MHS إلى Message Store.
MS - Message Store مخزن الرسائل	صندوق الرسائل على الخادم.	يخزن الرسائل حتى يسترجعها المستخدم.
MHS - Message Handling System نظام معالجة الرسائل	النظام الوسيط للبريد.	يشمل MSA و MTAs و MDA.

الكاتب / Author

|
v

MUA --ESMTP Submission--> MSA --SMTP--> MTA --SMTP--> MTA --SMTP/local--> MDA --> MS
|
v
POP3 / IMAP / local
|
v
عند المستقبل MUA

احفظ المسار: MUA -> MSA -> MTA(s) -> MDA -> MS -> MUA. النقل بين الخوادم غالباً SMTP، والاسترجاع من صندوق البريد POP3/IMAP.

Email Protocols (2) / بروتوكولات البريد الإلكتروني

النوع	البروتوكول	الاستخدام
نقل الرسائل عبر الإنترنت	SMTP - Simple Mail Transfer Protocol	تحريك الرسائل من المصدر إلى الوجهة عبر MTAs.
استرجاع الرسائل من الخادم	IMAP و POP3	تمكين عميل البريد من قراءة الرسائل من خادم بعيد.

SMTP / بروتوكول نقل البريد البسيط

- **SMTP / Simple Mail Transfer Protocol**: بروتوكول نصي text-based client-server.
- يغلف الرسالة داخل Envelope وينقلها من المصدر إلى الوجهة عبر عدة MTAs.
- حدد أولاً في RFC 821 عام 1982.
- **ESMTP - Extended SMTP**: الاسم المستخدم للإصدارات/الامتدادات اللاحقة من SMTP.

مثال معاملة SMTP / SMTP Transaction Scenario

```
C: opens TCP connection to foo.com on port 25
S: 220 foo.com Simple Mail Transfer Service Ready
C: HELO bar.com
S: 250 OK
C: MAIL FROM:<Smith@bar.com>
S: 250 OK
C: RCPT TO:<Jones@foo.com>
S: 250 OK
C: RCPT TO:<Green@foo.com>
S: 550 No such user here
C: DATA
S: 354 Start mail input; end with <CRLF>.<CRLF>
C: message body ...
C: <CRLF>.<CRLF>
S: 250 OK
C: QUIT
S: 221 Service closing transmission channel
```

الرموز المهمة: 220 جاهز، 250 OK قبول، 550 مستخدم غير موجود، 354 ابدأ إدخال الرسالة، 221 إغلاق الاتصال.

STARTTLS (3) / بدء TLS داخل SMTP

- **STARTTLS**: امتداد أمني مهم لـ SMTP.
- معرّف في RFC 3207.
- يضيف السرية / Confidentiality و المصادقة / Authentication بين وكلاء SMTP.
- يحمي الاتصال من المتنصتين / Eavesdroppers و المهاجمين / Attackers.
- ميزته: نفس منفذ SMTP يمكنه تقديم اتصال عادي أو آمن، دون الحاجة لمنفذين منفصلين.

STARTTLS يحمي القناة بين خوادم البريد، لكنه ليس مثل S/MIME الذي يحمي محتوى الرسالة نفسها من طرف إلى طرف.

Mail Access Protocols (4) / بروتوكولات الوصول للبريد

المقارنة	POP3 / Post Office Protocol	IMAP / Internet Mail Access Protocol
الفكرة	تنزيل البريد من الخادم.	الوصول إلى البريد الموجود على الخادم.
المنفذ	TCP 110	TCP 143
بعد التفويض	يمكن إصدار أوامر لاسترجاع وحذف البريد.	يوفر وظائف أكثر من POP3.
القوة	أبسط.	أكثر تعقيداً ويدعم مصادقة أقوى ووظائف إضافية.

RFC 5322 (5) / صيغة رسائل البريد النصية

- RFC 5322 يحدد صيغة الرسائل النصية المرسل بالبريد الإلكتروني.
- ينظر للرسالة على أنها: طرف / Envelope + محتويات / Contents.
- Envelope: معلومات النقل والتسليم.
- Contents: الكائن الفعلي الذي يصل للمستقبل.
- ينطبق فقط على بنية وصيغة الرسالة في طبقة التطبيق / Application Layer.

Date: October 8, 2009 2:15:49 PM EDT
From: "William Stallings" <ws@shore.net>
Subject: The Syntax in RFC 5322
To: Smith@Other-host.com
Cc: Jones@Yet-Another-Host.com

Hello. This section begins the actual message body,
which is delimited from the message heading by a blank line.

النقطة الامتحانية: يوجد سطر فارغ يفصل Header عن Body.

Limitations of SMTP/RFC 5322 / قيود SMTP و RFC 5322

- SMTP لا يستطيع نقل ملفات تنفيذية / Executable files أو كائنات ثنائية مباشرة.
- لا يدعم جيداً نصوصاً تحتوي على حروف لغات وطنية/غير ASCII.
- قد ترفض الخوادم رسائل أكبر من حجم معين.
- بوابات التحويل بين ASCII و EBCDIC قد تسبب مشاكل ترجمة.
- بوابات SMTP إلى شبكات X.400 قد لا تتعامل مع بيانات غير نصية.
- بعض تطبيقات SMTP لا تلتزم كلياً بمعيار RFC 821.

MIME (7) / امتدادات البريد متعددة الأغراض

تعريف MIME / Definition

- MIME - Multipurpose Internet Mail Extensions: امتداد لإطار RFC 5322 لمعالجة قيود SMTP.
- صمم ليحل مشاكل SMTP بطريقة متوافقة مع تطبيقات RFC 5322 الحالية.
- محدد في RFCs 2045-2049.

مواصفات MIME / MIME Specifications

- يعرف خمسة حقول Header جديدة.
- يعرف صيغ محتوى تدعم البريد متعدد الوسائط.
- يعرف Transfer encodings لتحويل أي محتوى إلى صيغة آمنة أثناء النقل.

The Five Header Fields Defined in MIME / حقول MIME الخمسة

الحقل	وظيفته المختصرة
MIME-Version	يجب أن تكون قيمته 1.0، ويؤكد أن الرسالة مطابقة لـ RFC 2045/2046.
Content-Type	يصف نوع البيانات في جسم الرسالة حتى يختار العميل طريقة العرض المناسبة.
Content-Transfer-Encoding	يبين التحويل المستخدم لتمثيل جسم الرسالة بطريقة صالحة للنقل البريدي.
Content-ID	يميز كيانات MIME بشكل فريد في سياقات متعددة.
Content-Description	وصف نصي للكائن داخل الجسم، مفيد إذا كان الكائن غير مقروء مباشرة.

MIME Content Types / أنواع محتوى MIME

النوع / Type	Subtypes / الأنواع الفرعية المهمة	الفكرة
Text	plain, enriched	نص عادي أو نص بتنسيق أكبر.
Multipart	mixed, parallel, alternative, digest	عدة أجزاء داخل رسالة واحدة؛ mixed بترتيب، alternative نسخ بديلة لنفس المعلومة.
Message	rfc822, partial, external-body	رسالة مغلفة، أو أجزاء، أو مؤشر لكائن خارجي.
Image	jpeg, gif	صور.
Video	mpeg	فيديو MPEG.
Audio	basic	صوت أساسي.
Application	PostScript, octet-stream	بيانات تطبيقات أو بيانات ثنائية عامة.

MIME Transfer Encodings / ترميزات النقل

Encoding	المعنى المختصر
7bit	أسطر قصيرة من ASCII فقط.
8bit	أسطر قصيرة وقد تحتوي على non-ASCII.
binary	قد يحتوي على non-ASCII والأسطر ليست مناسبة دائماً لـ SMTP.
quoted-printable	يحافظ على قابلية قراءة النص إذا كان أغلبه ASCII.
base64	يحول 6-bit input blocks إلى 8-bit printable ASCII.
x-token	ترميز غير قياسي مسمى.

MIME حل مشكلة نقل الصور/الصوت/الفيديو/الملفات الثنائية داخل البريد عبر Content-Type و Transfer-Encoding.

Email Security Threats (8) / تهديدات أمن البريد

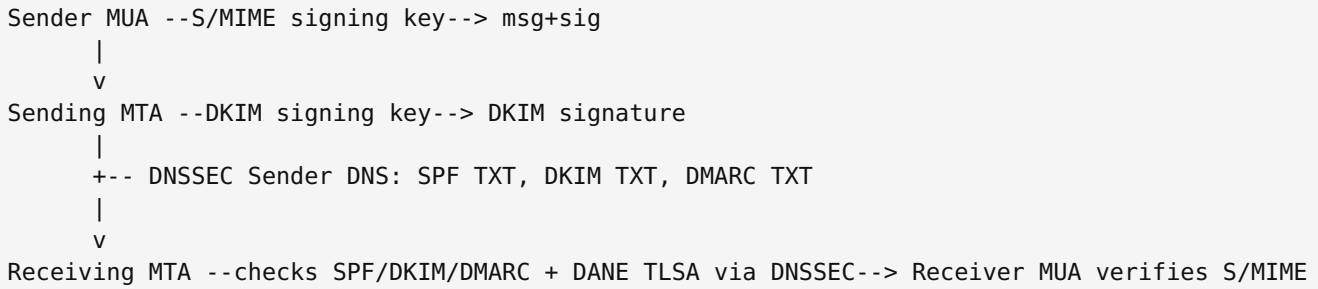
نوع التهديد	النتيجة
Authenticity-related threats تهديدات الأصالة	وصول غير مصرح إلى نظام البريد أو انتحال مصدر الرسالة.
Integrity-related threats تهديدات السلامة	تعديل غير مصرح لمحتوى البريد.
Confidentiality-related threats تهديدات السرية	كشف معلومات حساسة.
Availability-related threats تهديدات التوفر	منع المستخدمين من إرسال أو استقبال البريد.

Email Threats and Mitigations / التهديدات والمعالجات

Threat / التهديد	الأثر المختصر	Mitigation / المعالجة
بريد مرسل من MTA غير مصرح داخل المؤسسة، مثل malware botnet	فقدان سمعة الدومين، وقد يتم حظر بريد صحيح، وإرسال روابط خبيثة للمستقبل.	تقنيات مصادقة الدومين + توقيعات رقمية.
رسالة باستخدام دومين مرسل مزيف أو غير مسجل.	Spam/Phishing واحتمال حظر الدومين الصحيح.	Domain-based authentication + digital signatures.
عنوان مرسل مزور أو بريد تصيدي phishing/spear phishing.	خداع المستخدم وتسريب معلومات حساسة أو PII.	مصادقة الدومين والتوقيع الرقمي.
تعديل البريد أثناء النقل.	محتوى معدل أو خبيث وتسريب معلومات.	TLS بين الخوادم + تشفير بريد من طرف إلى طرف.
كشف معلومات حساسة عبر مراقبة حركة البريد.	تسريب PII أو معلومات حساسة.	TLS + end-to-end encryption.
UBE / Unsolicited Bulk Email Spam	بريد مزعج وروابط خبيثة في inbox.	تقنيات مكافحة UBE.
DoS/DDoS على خوادم البريد.	عدم القدرة على الإرسال/الاستقبال.	خوادم متعددة واستخدام مزودي بريد سحابي.

Counter Threat Protocols (9) / بروتوكولات مواجهة التهديدات

Protocol	ماذا يوفر؟
STARTTLS	امتداد SMTP يوفر authentication, integrity, non-repudiation, confidentiality للرسالة أثناء تشغيل SMTP فوق TLS.
S/MIME	يوفر authentication, integrity, non-repudiation, confidentiality لجسم الرسالة داخل SMTP.
DNSSEC	مصادقة وسلامة بيانات DNS؛ أداة أساسية لبروتوكولات أمن البريد.
DANE	بدل/داعم لمشكلة CA، يربط مفاتيح/شهادات TLS بـ DNSSEC.
SPF	يربط الدومين بعناوين IP المصرح لها بإرسال البريد.
DKIM	MTA يوقع headers مختارة وجسم الرسالة للتحقق من الدومين وسلامة الجسم.
DMARC	يخبر المستقبل ماذا يفعل عند فشل SPF/DKIM ويوفر تقارير للمرسل.



الفكرة: SPF/DKIM/DMARC يثبتون هوية الدومين وسياسة التعامل، أما S/MIME يثبت ويحمي الرسالة نفسها للمستخدم.

S/MIME / Secure/Multipurpose Internet Mail (10 Extensions

تعريف S/MIME

- S/MIME: تحسين أمني لمعيار MIME للبريد الإلكتروني، مبني على تقنية RSA Data Security.
- يعتمد على Public-key certificates و Cryptographic Message Syntax (CMS).
- وثائق مهمة: RFC 5750, 5751, 4134, 2634, 5652, 3370, 5752, 1847.

S/MIME خدمات / Summary of S/MIME Services

الخدمة	الخوارزميات/الأدوات	الفكرة
Digital signature	DSS/SHA or RSA/SHA	إنشاء hash للرسالة ثم تشفيره بالمفتاح الخاص للمرسل وإرفاقه.
Message encryption	CAST/IDEA/3DES + DH/RSA	تشفير الرسالة بمفتاح جلسة مرة واحدة، ثم تشفير مفتاح الجلسة بمفتاح المستقبل العام.
Compression	ZIP	ضغط الرسالة للتخزين أو النقل.
E-mail compatibility	Radix-64/Base64	تحويل البيانات المشفرة إلى نص ASCII مناسب للبريد.

Authentication by Digital Signature / المصادقة بالتوقيع الرقمي

1. المرسل ينشئ الرسالة.
2. يستخدم SHA-256 لإنشاء 256-bit message digest.
3. يشقّ الـ digest باستخدام RSA + sender private key ويرفق النتيجة مع معلومات تعريف الموقع.
4. المستقبل يستخدم sender public key لفك تشفير الـ digest.
5. المستقبل يحسب digest جديد للرسالة ويقارنه بالـ digest المسترجع.
6. إذا تطابقا: الرسالة أصلية ولم تتغير.

التوقيع الرقمي يعطي: Authentication + Integrity + Non-repudiation.

Confidentiality / السرية بالتشفير

- S/MIME يوفر السرية عبر تشفير الرسالة.
- الأكثر شيوعاً: AES 128-bit CBC.
- مفتاح المحتوى Content-encryption key يستخدم مرة واحدة فقط.
- ينشأ مفتاح عشوائي جديد لكل رسالة.
- يتم تشفير المفتاح نفسه عادة بـ RSA باستخدام المفتاح العام للمستقبل.
- استخدام مزيج Symmetric + Public-key encryption يقلل وقت التشفير.

S/MIME Functional Flow / تدفق S/MIME

Sender:

Message -> Sign with sender private key (RSA/SHA-256) -> Msg + Sig
-> Encrypt Msg+Sig with one-time AES-128 CBC key
-> Encrypt one-time key with receiver public key (RSA)
-> Send encrypted package

Receiver:

Encrypted package -> Decrypt session key with receiver private key
-> Decrypt message with AES key
-> Verify signature with sender public key

E-mail Compatibility / التوافق مع أنظمة البريد

- كثير من أنظمة البريد تسمح فقط بـ ASCII text.
- S/MIME يحول الـ 8-bit binary stream إلى printable ASCII.
- الآلية: Base64 conversion.
- كل 3 octets من البيانات الثنائية تتحول إلى 4 ASCII characters.
- Base64 يحول المدخلات بغض النظر عن نوعها حتى لو كانت أصلاً ASCII.

Compression / الضغط

- S/MIME يمكنه ضغط الرسالة لتوفير مساحة النقل والتخزين.
- يمكن تطبيق الضغط قبل أو بعد التوقيع/التشفير.
- ضغط البيانات المشفرة binary غالباً لا يعطي فائدة كبيرة.
- إذا كان الضغط lossy مع التوقيع: اضغط أولاً ثم وقّع.

S/MIME Message Content Types / أنواع محتوى S/MIME

Content Type	المعنى
Data	المحتوى الداخلي المشفر بصيغة MIME، ويمكن تغليفه لاحقاً في SignedData / EnvelopedData/CompressedData.
SignedData	يستخدم لتطبيق توقيع رقمي على الرسالة.
EnvelopedData	محتوى مشفر + مفاتيح تشفير محتوى مشفرة لواحد أو أكثر من المستقبلين.
CompressedData	تطبيق ضغط بيانات على الرسالة.
Clear signing	الرسالة والتوقيع يكونان كـ multipart MIME، ويمكن قراءة الرسالة حتى بدون دعم S/MIME.

الخوارزميات / Cryptographic Algorithms Used in S/MIME

الوظيفة	المتطلبات المهمة
إنشاء message digest للتوقيع	MUST: SHA-256. SHOULD: SHA-1. Receiver SHOULD: MD5.
استخدام digest لتكوين توقيع رقمي	MUST: RSA with SHA-256. SHOULD: DSA/SHA-256, RSASSA-PSS/SHA-256, RSA/SHA-1, DSA/SHA-1, RSA/MD5.
تشفير مفتاح الجلسة للإرسال	MUST: RSA encryption. SHOULD: RSAES-OAEP, Diffie-Hellman ephemeral, static.
تشفير الرسالة بمفتاح جلسة مرة واحدة	MUST: AES-128 CBC. SHOULD: AES-192 CBC, AES-256 CBC, Triple DES, CBC.

EnvelopedData خطوات / EnvelopedData Steps

1. توليد pseudorandom session key لخوارزمية تشفير متماثل.
2. لكل مستقبل: تشفير مفتاح الجلسة بمفتاحه العام RSA.
3. لكل مستقبل: تجهيز RecipientInfo يحتوي معرف شهادة المستقبل، وخوارزمية تشفير المفتاح، ومفتاح الجلسة المشفر.
4. تشفير محتوى الرسالة بمفتاح الجلسة.

SignedData خطوات / SignedData Steps

1. اختيار خوارزمية digest مثل SHA أو MD5.
2. حساب message digest للمحتوى المراد توقيعه.
3. تشفير digest بالمفتاح الخاص للموقع.
4. تجهيز SignerInfo ويحتوي شهادة الموقع، معرف خوارزمية digest، معرف خوارزمية التشفير، وال digest المشفر.

Clear Signing / التوقيع الواضح

- يتحقق باستخدام multipart content type مع signed subtype.
- لا يتطلب تحويل الرسالة الأصلية المراد توقيعها.
- مستقبل لديه MIME بدون S/MIME يستطيع قراءة الرسالة.

S/MIME Certificate Processing / معالجة الشهادات

- S/MIME يستخدم شهادات مفتاح عام متوافقة مع X.509 version 3.
- يجب إعداد العميل بقائمة مفاتيح موثوقة وقوائم إبطال الشهادات CRLs.
- المسؤولية محلية في حفظ الشهادات اللازمة للتحقق من التوقيعات الواردة وتشفير الرسائل الصادرة.
- الشهادات موقعة من Certification Authorities / CAs.

User Agent Role / دور وكيل المستخدم في إدارة المفاتيح

الوظيفة	المطلوب
Key generation	توليد أزواج مفاتيح Diffie-Hellman و DSS، ويفضل القدرة على توليد RSA. RSA بين 768 و 1024 بت، ولا يقل عن 512 بت.
Registration	تسجيل المفتاح العام مع CA للحصول على شهادة X.509.
Certificate storage and retrieval	الوصول لقائمة شهادات محلية للتحقق من التوقيعات الواردة وتشفير الرسائل الصادرة.

Enhanced Security Services / الخدمات الأمنية المحسنة

الخدمة	المعنى
Signed receipt	إيصال موقع يثبت للمرسل أن المستقبل استلم الرسالة.
Security labels	معلومات حساسية المحتوى المحمي بتغليف S/MIME.
Secure mailing lists	وكيل قائمة بريد S/MIME يمكنه تشفير الرسالة لكل مستقبل وإعادة توجيهها.
Signing certificates	ربط شهادة المرسل بتوقيعه بأمان عبر خاصية signing certificate attribute.

Lecture 4 / المحاضرة الرابعة

Electronic Mail Security Part 2 / أمن البريد الإلكتروني - الجزء الثاني

PGP / Pretty Good Privacy (1)

- PGP - Pretty Good Privacy: بروتوكول بديل لأمن البريد، له تقريباً نفس وظائف S/MIME.
- أنشأه Phil Zimmerman وصدر كمنتج عام 1991.
- أتيح مجاناً وأصبح شائعاً للاستخدام الشخصي.
- البروتوكول الأول كان proprietary واستخدم خوارزميات عليها قيود ملكية فكرية.
- OpenPGP معيار جديد مبني على PGP version 5.x.
- OpenPGP معرف في RFC 4880 و RFC 3156.
- أهم فرقين بين S/MIME و OpenPGP: Key Certification و Key Distribution.
- NIST 800-177 يوصي بـ S/MIME بدلاً من PGP بسبب ثقة أكبر في نظام CA للتحقق من المفاتيح العامة.

امتحانياً: $PGP \approx S/MIME$ في الوظائف، لكن الاختلاف المهم في طريقة توثيق وتوزيع المفاتيح.

DNS / Domain Name System (2)

تعريف DNS / Definition

- DNS: خدمة دليل/بحث تحول اسم المضيف على الإنترنت إلى عنوان IP رقمي.
- ضروري لعمل الإنترنت.
- تستخدمه MUAs و MTAs لإيجاد عنوان الخادم التالي في تسليم البريد.
- يتكون من أربعة عناصر: Domain name space، DNS database، Name servers، Resolvers.

DNS Database / قاعدة بيانات DNS

- قاعدة هرمية تحتوي Resource Records - RRs.
- تتضمن RRs الاسم، عنوان IP، ومعلومات أخرى عن المضيف.
- خصائصها: variable-depth hierarchy، قاعدة موزعة، والتوزيع محكوم بالقاعدة نفسها.
- تقدم DNS servers خدمة تحويل name-to-address للتطبيقات.

DNS / حل أسماء DNS Name Resolution

```
User program -> Name resolver -> local cache?
      |
      v
Name server -> database/cache
      |
      +--> Foreign name server -> database/cache
      |
      v
Response -> Name resolver -> User program
```

DNS / أنواع سجلات Resource Record Types

الوصف المختصر	Type
يربط اسم النظام بعنوان IPv4.	A
مثل A لكن لعناوين IPv6.	AAAA
اسم مستعار alias يربط الاسم بالاسم الحقيقي canonical.	CNAME
معلومات المضيف: المعالج ونظام التشغيل.	HINFO
معلومات صندوق بريد أو قائمة بريد.	MINFO
Mail Exchange: يحدد خادم/خوادم تسليم البريد للدومين.	MX
خادم اسم موثوق لهذا الدومين.	NS
مؤشر لجزء آخر من فضاء أسماء الدومين.	PTR
بداية سلطة المنطقة، ويحتوي إعدادات zone.	SOA
يحدد الخادم/الخوادم التي تقدم خدمة معينة.	SRV
نص حر؛ مهم لـ SPF/DKIM/DMARC.	TXT
الخدمات المعروفة المتوفرة على المضيف.	WKS

DNSSEC / DNS Security Extensions (3

- DNSSEC: امتدادات أمن DNS.
- تستخدمها عدة بروتوكولات توفر أمن البريد الإلكتروني.
- توفر حماية end-to-end باستخدام Digital signatures.
- التوقيعات ينشئها مسؤولو zone المستجيبة، ويتحقق منها resolver عند المستقبل.
- تقلل الحاجة للثقة في name servers و resolvers الوسيطة التي تقوم بالتخزين أو التوجيه.
- تتكون من أنواع RRs جديدة وتعديلات على DNS.
- المراجع: RFC 4033, RFC 4034, RFC 4035.

DNSSEC / طريقة عمل DNSSEC Operation

- يحمي DNS clients من قبول RRs مزيفة أو معدلة.
- يستخدم التوقيعات الرقمية لتقديم:

الخدمة	المعنى
Data origin authentication	التأكد أن البيانات جاءت من المصدر الصحيح.
Data integrity verification	التأكد أن محتوى RR لم يتم تعديله.

- الثقة تبدأ من Trusted zone ثم تنزل عبر Chain of trust.
- المفتاح العام للمنطقة الموثوقة يسمى Trust anchor.

```

Trust Anchor (Root public key)
  |
  v
Parent zone verifies/signs child public key
  |
  v
Child zone verifies/signs lower zone/key
  |
  v
Resolver verifies RR signature -> accept DNS answer

```

DNSSEC سجلات / Resource Records for DNSSEC

RR	المعنى
DNSKEY	يحتوي مفتاحاً عاماً.
RRSIG	توقيع رقمي لسجل مورد.
NSEC	سجل إنكار وجود موثق: يثبت أن اسم/نوع سجل غير موجود.
DS - Delegation Signer	يسهل ربط التوقيع والمصادقة بين DNS zones لإنشاء authentication chain.

DS يبني سلسلة الثقة، و NSEC يؤمن الردود السلبية مثل: هذا الاسم غير موجود.

DANE / DNS-Based Authentication of Named (4 Entities

- DANE: يسمح بربط شهادات X.509 المستخدمة في TLS بأسماء DNS باستخدام DNSSEC.
- مقترح في RFC 6698.
- يستخدم لمصادقة TLS client/server بدون الاعتماد الكامل على CA - Certificate Authority.
- هدفه: استبدال الاعتماد على CA system بالاعتماد على الأمن المقدم من DNSSEC.

DANE / The Rationale for DANE

- المشكلة: نظام PKI العالمي يعتمد على مئات CAs ك trust anchors داخل المتصفحات وأنظمة التشغيل.
- إذا تم اختراق CA واحدة، يمكن للمهاجم الحصول على المفتاح الخاص أو إصدار شهادات مزيفة.
- لا يوجد نطاق محدود للتأثير: اختراق CA واحدة يضعف سلامة PKI كله.
- بعض CAs لديها ممارسات أمنية ضعيفة.

TLSA Record / سجل TLSA

- DANE يعرف نوع سجل DNS جديد: TLSA.
- يستخدم لمصادقة شهادات SSL/TLS بطريقة آمنة.
- يوفر:
- 1. تحديد القيود على أي CA يمكنها تأكيد الشهادة.
- 2. إمكانية مصادقة شهادة خدمة أو CA مباشرة داخل DNS نفسه.
- مالِك الدومين ينشئ TLSA RR يحدد الشهادة ومفتاحها العام.
- عند استقبال شهادة X.509 في TLS، يبحث العميل عن TLSA RR ويطابقها مع الشهادة ضمن التحقق.

```
TLSA RR transmission format:
0      8      16      24      31
+-----+-----+-----+-----+
| Cert.  |Selector|Matching|      |
| usage  |      | type   |Certificate|
+-----+-----+-----+ association |
|                        data          |
+-----+-----+-----+-----+
```

SPF / Sender Policy Framework (5

- SPF: طريقة معيارية تجعل دومين الإرسال يحدد ويؤكد خوادم البريد المصرح لها بالإرسال عنه.
- معرف في RFC 7208.
- يسمح لـ ADMDs بتفويض hosts لاستخدام أسماء دومينهم في MAIL FROM أو HELO.
- يعمل بفحص عنوان IP للمرسل مقابل سياسة SPF المخزنة في سجل SPF للدومين.
- يمكن تطبيق فحص SPF قبل استلام محتوى الرسالة.

SPF يفحص Envelope MAIL FROM / HELO وليس بالضرورة عنوان From: الظاهر للمستخدم.

SPF Flow / تدفق SPF

```
Incoming mail server receives connection
|
v
Extract sender IP + MAIL FROM/HELO domain
|
v
DNS lookup for SPF record
|
v
Compare IP against SPF policy
|
+--> pass/fail -> further policy checks -> Inbox / Junk / Quarantine / Block
```

SPF SMTP Example / مثال SPF في جلسة SMTP

```
S: 220 foo.com Simple Mail Transfer Service Ready
C: HELO mta.example.net
S: 250 OK
C: MAIL FROM:<alice@example.org>    <-- SPF checks this domain / HELO identity
```

```

S: 250 OK
C: RCPT TO:<Jones@foo.com>
S: 250 OK
C: DATA
C: To: bob@foo.com
C: From: alice.sender@example.net    <-- visible header, not the same necessarily
C: Subject: Meeting Today

```

SPF آليات / SPF Mechanisms

الوصف	Tag
IPv4 address/range مصرح له بالإرسال للدومين.	ip4
IPv6 address/range مصرح له بالإرسال للدومين.	ip6
الخوادم المدرجة في MX RRs تعتبر مرسلين صالحين.	mx
يجعل المستقبل يبحث في SPF لدومين آخر؛ مفيد للمنظمات ذات دومينات متعددة.	include
يطابق كل IP لم يطابق شيئاً سابقاً.	all

SPF محددات / SPF Modifiers

المعنى	Modifier
يجب أن ينجح الفحص؛ هو الافتراضي ولا يحتاج كتابته.	+
غير مسموح لهذا mechanism أن يرسل نيابة عن الدومين.	-
Softfail/مرحلة انتقالية: يقبل البريد لكن يعلم للفحص الأقرب.	~
Neutral: لا يصرّح بشيء واضح؛ السلوك الافتراضي القبول غالباً.	?

DKIM / DomainKeys Identified Mail (6

- DKIM: معيار لتوقيع رسائل البريد تشفيرياً، يسمح لدومين التوقيع أن يعلن مسؤوليته عن الرسالة.
- المستقبل يتحقق من التوقيع بالاستعلام مباشرة عن دومين الموقع لجلب المفتاح العام المناسب.
- إذا نجح التحقق: الرسالة صدرت من جهة تملك المفتاح الخاص لدومين التوقيع ولم تتغير الأجزاء الموقعة.
- معرف في RFC 6376.
- مستخدم على نطاق واسع لدى مزودي البريد و ISPs.

DKIM مستويات تهديد / E-mail Threats motivating DKIM

المستوى	الوصف
منخفض	مهاجم يريد فقط إرسال بريد لا يريد المستقبل استلامه.
متوسط	مرسلو spam محترفون يعملون تجارياً ويرسلون نيابة عن أطراف أخرى.
عالي	مهاجمون بدافع مالي كبير مثل الاحتيال عبر البريد.

Mail origination network:

MUA -> MSA --signs with DKIM private key--> MTA



DNS publishes DKIM public key

Mail delivery network:

Receiving MTA/MDA -> DNS public key query/response -> Verifier -> MUA

التدفق الوظيفي / DKIM Functional Flow

RFC 5322 message



Originating/relaying ADMD signs message with SDID using private key



Internet



Relaying/delivering ADMD: Is message signed?

| yes



Verify signature using DNS public key

| pass/fail



Assessments + reputation/accreditation -> Message filtering engine

| no



Check signing practices

|



DKIM لا يقول وحده ماذا تفعل عند الفشل؛ DMARC هو الذي يضيف سياسة التعامل مع الفشل.

,DMARC / Domain-Based Message Authentication (7 Reporting, and Conformance

- DMARC: مصادقة رسائل مبنية على الدومين + تقارير + توافق.
- يسمح للمرسلين بتحديد سياسة التعامل مع بريدهم.
- يحدد أنواع التقارير التي يمكن للمستقبلين إرسالها للمرسل وتكرارها.
- معرف في RFC 7489، مارس 2015.

DMARC Functional Flow / التدفق الوظيفي

```
Sender:
Author composes email -> Sending server attaches DKIM signature + SPF identity
|
v
Receiver:
Standard validation tests (blacklists, reputation, rate limits...)
|
+--> Retrieve verified DKIM domain
+--> Retrieve envelope-from via SPF
|
v
Apply DMARC policy
|
+--> Pass -> standard processing / inbox
|
+--> Fail -> Block or Quarantine + send failure/aggregate reports
```

DMARC Tags / وسوم DMARC المهمة

Tag	القيمة/المعنى المختصر
v	Version؛ يجب أن تكون أول عنصر. القيمة: DMARC1.
p	Policy إلزامي: none لا إجراء، quarantine عزل، reject رفض.
aspf	سياسة تطابق SPF: relaxed r افتراضي، strict s.
adkim	سياسة تطابق DKIM: relaxed r افتراضي، strict s.
fo	خيارات تقارير الفشل: 0 عند فشل كل الآليات 1، alignment عند فشل أي آلية، d لفشل s، DKIM لفشل SPF.
ruf	URI لإرسال تقارير فشل/forensic.
rua	URI لإرسال تقارير aggregate.
ri	Reporting interval، الافتراضي 86400 ثانية.
pct	النسبة المئوية من بريد الدومين التي تطبق عليها السياسة، الافتراضي 100.
sp	Receiver policy للدومينات الفرعية؛ مثل p، والافتراضي none.

أشهر سجل DMARC للحفظ: v=DMARC1; p=quarantine; rua=mailto:reports@example.com; pct=100

8) مقارنة نهائية / Final Comparison

Protocol	يحمي ماذا؟	نقطة الحفظ
STARTTLS	قناة SMTP بين خوادم/وكلاء البريد.	TLS للقناة وليس بالضرورة محتوى end-to-end.
S/MIME	محتوى الرسالة وتوقيعها للمستخدمين.	يعتمد على X.509 و CA.
PGP/OpenPGP	محتوى الرسالة مثل S/MIME.	فرق مهم في key certification/distribution.
DNSSEC	صحة وسلامة سجلات DNS.	Digital signatures + chain of trust + trust anchor.
DANE/TLSA	ربط شهادة TLS بالدومين عبر DNSSEC.	يقلل الاعتماد على CA system.
SPF	من يحق له الإرسال عن الدومين.	يفحص IP مقابل MAIL FROM/HELO.
DKIM	توقيع الرسالة بدومين معين.	المفتاح العام في DNS.
DMARC	سياسة التعامل مع SPF/DKIM + تقارير.	p=none/quarantine/reject.

9) Memory Sheet / ورقة الحفظ السريعة

البنية: MUA -> MSA -> MTA(s) -> MDA -> MS -> MUA
النقل: SMTP / ESMTP، والحماية القنوية STARTTLS.
الاسترجاع: POP3:110، IMAP:143.
صيغة الرسالة: RFC 5322 = envelope + contents، و MIME يحل مشكلة الملفات الثنائية والوسائط.
التهديدات: authenticity, integrity, confidentiality, availability.
S/MIME: توقيع = hash ثم private key، تشفير = session key ثم public key للمستقبل.
PGP: بديل لـ S/MIME، OpenPGP في RFC 4880/3156.
DNSSEC: DNSKEY/RRSIG/NSEC/DS، ويوفر origin authentication + integrity.
DANE: TLSA يربط TLS certificates بـ DNSSEC.
SPF: IP authorized senders.
DKIM: signature + DNS public key.
DMARC: policy + reporting فوق SPF/DKIM.